

Security Assessment Report

QA Test Target — <http://test-target:5001>
Scanned on July 12, 2026 at 09:39 UTC

42

Overall Security Score: 42 / 100

11 issues found out of 15 checks performed.

Executive Summary

QA Test Target is currently in a weak security position, with significant issues that need attention, with an overall security score of 42 out of 100. This scan identified 1 critical issue requiring immediate attention, 3 moderate issues, and 4 minor issues. We strongly recommend addressing the critical and high-priority items as soon as possible, as these represent the most significant risk to the site and its users.

Recommended Actions

- CRITICAL** Remove these files from the publicly served directory, or configure the web server to block access to them.
- MEDIUM** Add a Content-Security-Policy header that restricts script, style, and object sources to trusted origins.
- MEDIUM** Add a Strict-Transport-Security header with a max-age of at least 1 year, and consider includeSubDomains and preload.
- MEDIUM** Add an X-Frame-Options header set to DENY or SAMEORIGIN, and/or a Content-Security-Policy with a frame-ancestors directive.
- LOW** Add an X-Content-Type-Options header set to nosniff.
- LOW** Add a Referrer-Policy header set to strict-origin-when-cross-origin or no-referrer.
- LOW** Add a Permissions-Policy header restricting features not required by the site, e.g. camera=(), microphone=(), geolocation=().
- LOW** Configure the web server to suppress or generalize the Server header (e.g. ServerTokens Prod on Apache, server_tokens off on nginx).

Detailed Findings

SEVERITY	FINDING	EVIDENCE	RECOMMENDATION
MEDIUM	Missing Content-Security-Policy header The response did not include a Content-Security-Policy header, leaving the site more exposed to XSS and data injection attacks.	Content-Security-Policy header not present.	Add a Content-Security-Policy header that restricts script, style, and object sources to trusted origins.
MEDIUM	Missing Strict-Transport-Security header The response did not include an HSTS header, so browsers will not be instructed to only connect over HTTPS, leaving users exposed to protocol-downgrade and man-in-the-middle attacks.	Strict-Transport-Security header not present.	Add a Strict-Transport-Security header with a max-age of at least 1 year, and consider includeSubDomains and preload.
MEDIUM	Missing X-Frame-Options header The response did not include an X-Frame-Options header, so the site can potentially be embedded in an iframe on a malicious page and used for clickjacking attacks.	X-Frame-Options header not present.	Add an X-Frame-Options header set to DENY or SAMEORIGIN, and/or a Content-Security-Policy with a frame-ancestors directive.

SEVERITY	FINDING	EVIDENCE	RECOMMENDATION
LOW	Missing X-Content-Type-Options header The response did not include an X-Content-Type-Options header, so browsers may MIME-sniff the response body and interpret it as a different content type than declared, which can enable certain content-injection attacks in specific scenarios (e.g. user-uploaded content served from the same origin).	X-Content-Type-Options header not present.	Add an X-Content-Type-Options header set to nosniff.
LOW	Missing Referrer-Policy header The response did not include a Referrer-Policy header. Modern browsers default to a reasonably safe policy (strict-origin-when-cross-origin), but explicitly setting this header ensures consistent, intentional behavior across all browsers and versions.	Referrer-Policy header not present.	Add a Referrer-Policy header set to strict-origin-when-cross-origin or no-referrer.

SEVERITY	FINDING	EVIDENCE	RECOMMENDATION
LOW	Missing Permissions-Policy header The response did not include a Permissions-Policy header, so no restrictions are placed on powerful browser features (camera, microphone, geolocation, payment, etc.) that injected or third-party scripts could otherwise attempt to access.	Permissions-Policy header not present.	Add a Permissions-Policy header restricting features not required by the site, e.g. camera=(), microphone=(), geolocation=().
INFO	Could not evaluate SSL certificate Could not complete a TLS handshake with the target, even with certificate validation disabled.	error=[SSL: WRONG_VERSION_NUMBER] wrong version number (_ssl.c:1016)	Ensure the target supports HTTPS and retry.
INFO	No TLS protocols detected ssllscan did not report any accepted protocol versions.	supported_protocols=[]	Manually inspect the server's TLS configuration.
INFO	No cipher information detected ssllscan did not report any accepted ciphers.	ciphers=[]	Manually inspect the server's TLS configuration.

SEVERITY	FINDING	EVIDENCE	RECOMMENDATION
CRITICAL	Exposed sensitive file(s) detected: 2 path(s) One or more sensitive files/paths (version control metadata, environment files, backups, etc.) were found publicly accessible, which can leak source code, credentials, or other sensitive data.	.git/HEAD (status=200); .git/config (status=200)	Remove these files from the publicly served directory, or configure the web server to block access to them.
LOW	Server header discloses version information The Server header includes specific version information, which can help an attacker identify known vulnerabilities for that exact version.	Server: Werkzeug/3.1.8 Python/3.11.15	Configure the web server to suppress or generalize the Server header (e.g. ServerTokens Prod on Apache, server_tokens off on nginx).

4 additional checks passed with no issues found.